

Hygiène Cryptographique et Sécurisation des Flux (TLS / SSH)

1. Concepts et Normes Cryptographiques Actuelles

La protection des données en transit repose sur l'utilisation de protocoles cryptographiques robustes. L'objectif est de garantir la confidentialité, l'intégrité et l'authenticité des communications face aux interceptions (Man-in-the-Middle).

1.1 Obsolescence des protocoles

Les recommandations de l'ANSSI (RGS) imposent le déclassement des protocoles obsolètes, vulnérables à des attaques connues (POODLE, BEAST, CRIME) :

- **Protocoles à désactiver impérativement** : SSLv2, SSLv3, TLS 1.0, TLS 1.1.
- **Protocoles autorisés** : TLS 1.2 (configuré strictement) et TLS 1.3.

1.2 Algorithmes et Suites Cryptographiques (Cipher Suites)

Un protocole robuste (comme TLS 1.2) peut être rendu vulnérable s'il négocie une suite cryptographique faible.

- **Hachage** : Les algorithmes MD5 et SHA-1 sont dépréciés en raison du risque de collision. SHA-256 ou supérieur est exigé.
- **Chiffrement symétrique** : RC4, DES et 3DES doivent être bloqués. L'utilisation d'AES (notamment en mode GCM) ou de ChaCha20 est requise.
- **Échange de clés et PFS** : Il est impératif d'utiliser des algorithmes garantissant la confidentialité persistante (Perfect Forward Secrecy - PFS), tels que ECDHE (Elliptic Curve Diffie-Hellman Ephemeral). Si la clé privée du serveur est compromise dans le futur, les communications passées ne pourront pas être déchiffrées.

2. Durcissement sous Windows : L'API Schannel

Sous Windows Server, la majorité des services natifs (IIS, RDP, WinRM, LDAPS) s'appuient sur un composant central du système d'exploitation nommé **Schannel** (Secure Channel) pour la gestion des protocoles TLS/SSL.

2.1 La configuration par Base de Registre

Schannel ne dispose pas d'interface graphique native de configuration. Les protocoles, les chiffrements et les algorithmes de hachage sont pilotés par des clés de registre situées dans le chemin suivant :

`HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\`

Pour désactiver un protocole (ex: TLS 1.0), il est nécessaire de créer les sous-clés **Client** et **Server**, et d'y configurer la valeur DWORD **Enabled** à 0.

2.2 Automatisation et Outillage

La modification manuelle de la base de registre pour des dizaines d'algorithmes étant sujette à erreur, l'industrie utilise des scripts PowerShell ou des utilitaires tiers (comme l'outil gratuit IISCrypto en mode ligne de commande) pour appliquer des modèles (Templates) conformes aux bonnes pratiques (ex: "Strict" ou "Best Practices"). *Note : Toute modification de la configuration Schannel nécessite un redémarrage du serveur Windows pour être prise en compte par le noyau.*

3. Durcissement sous Linux : OpenSSH

Sur les serveurs Linux, bien qu'OpenSSL gère la majorité des flux TLS (Apache, Nginx), le service d'administration OpenSSH requiert un durcissement spécifique dans son fichier de configuration principal (`/etc/ssh/sshd_config`).

3.1 Paramètres de chiffrement SSH

Par défaut, OpenSSH maintient une compatibilité ascendante avec des algorithmes vieillissants. L'administrateur doit restreindre explicitement les méthodes autorisées :

- **KexAlgorithms (Key Exchange)** : Limiter aux courbes elliptiques (ex: `curve25519-sha256`).
- **Ciphers (Chiffrement symétrique)** : Restreindre aux modes GCM et ChaCha20 (ex: `chacha20-poly1305@openssh.com, aes256-gcm@openssh.com`).
- **MACs (Message Authentication Codes)** : Exclure MD5 et SHA1 au profit d'algorithmes EtM (Encrypt-then-MAC) basés sur SHA-2 ou SHA-3 (ex: `hmac-sha2-512-etm@openssh.com`).

3.2 Implémentation

Ces directives doivent être ajoutées ou modifiées dans le fichier `sshd_config`. Après vérification de la syntaxe (`sshd -t`), le rechargement du service applique immédiatement les restrictions. Tout client SSH distant ne supportant pas ces algorithmes modernes verra sa

tentative de connexion rejetée au stade de la négociation (Handshake).